



Islamic University of Technology

Department of Computer Science and Engineering (CSE)

B.Sc. in Software Engineering

HUM 4747: Legal Issues and Cyber Law

Winter, 2024-2025

Assignment 3

Digital Forensics and Cyber Law

Namisa Najah Raisa

210042112

Program: B.Sc in SWE

Department of CSE

Date: April 14, 2026

Contents

1	The “Retail Ransom”	2
2	The “SpiderKash” Leak	5
3	Digital Forensics Tool	7
	References	8

1 The “Retail Ransom”

Question 1

Distinguishing exfiltration from local encryption comes down to three checks.

First, NetFlow and firewall logs reveal anomalous outbound spikes that encryption-in-place simply cannot produce [26].

Second, EDR telemetry exposes file-read bursts, staging artefacts, and C2 beaconing tied to the MITRE ATT&CK exfiltration tactic [29].

Third, file-system timelines flag read events followed by outbound connections, absent in pure encryption scenarios [13].

In Shwapno’s case, customer records surfacing on social media settled the question outright [34, 33]

Question 2

If I were the first responder to the Shwapno breach, I would follow these immediate steps to contain the situation and preserve evidence:

1. **Declare the Incident.** I would activate the Incident Response Plan (IRP), notify legal and executive management, and timestamp all actions for clear documentation.
2. **Isolate Affected Systems.** I would quarantine affected systems using VLAN isolation and firewall ACLs, without powering them off, to preserve volatile evidence such as encryption keys and attacker tools[23].
3. **Preserve Evidence.** I would capture full memory dumps and disk images, hash everything with SHA-256, and maintain chain-of-custody logs. The delayed filing of Shwapno’s GD shows why evidence preservation is vital[33].
4. **Identify the Initial Access Vector (IAV).** I would audit email gateway and authentication logs to confirm the phishing vector and close it to prevent re-infection[34].
5. **Reset Credentials and Search for Persistence.** I would enforce password resets for privileged accounts and search for persistence mechanisms like scheduled tasks or registry keys used for a secondary attack[28].
6. **Notify Authorities and Affected Parties.** I would immediately engage authorities such as the CTTC and issue a public advisory. Shwapno’s delay in disclosure attracted criticism, which should be avoided[35].

At this stage, I would not consider paying the ransom due to the legal and ethical risks involved[25].

Question 3

If the hackers encrypted the original database, a series of technical recovery options could be pursued before considering ransom payment:

1. **Volume Shadow Copy (VSS) Recovery.** Windows systems often create shadow copies of files. If the ransomware hasn't deleted these copies, checking for available snapshots using the command `vssadmin list shadows` could reveal unencrypted versions of the database, allowing for extraction without interaction with the attacker [23].
2. **Offline Backup Restoration.** The most reliable method of recovery is restoring from a recent, offline, or immutable backup. Backup strategies that include air-gapped or write-once storage (cloud or physical) remain unaffected by ransomware that targets accessible network shares [32].
3. **File Carving.** Forensic tools like *Autopsy* or *Sleuth Kit* can attempt to recover deleted or partially overwritten files from unallocated disk space. This is effective when ransomware encrypts a copy of the database while deleting the original [13].
4. **Decryption Key Recovery from Memory.** If the ransomware process is still running on the system, encryption keys may be stored in volatile memory (RAM). Memory forensics tools, such as *Volatility*, can be used to extract these keys and decrypt the files without engaging the attackers [27].
5. **Known Decryptors.** The *No More Ransom* initiative offers free decryptors for several ransomware families. If Shwapno's breach involved Qilin ransomware, a public decryptor might already be available, potentially allowing for file recovery without payment [33].
6. **Database Transaction Log Replay.** If any pre-encryption transaction logs are intact, a database administrator can replay the logs to restore the database to its last committed state, a technique that works for systems like SQL Server, MySQL, and PostgreSQL.

Only after exhausting these recovery methods, and if business continuity is critically jeopardized, should ransom payment be considered; and even then, only after consulting legal and regulatory advisors [30].

Question 4

Does Paying Constitute 'Aiding and Abetting'?

Under **Bangladesh law**, paying a \$1.5 million ransom could potentially constitute aiding and abetting cybercrime, depending on the circumstances and the recipient's status.

The **Digital Security Act 2018** and the **ICT Act 2006 (amended 2013)** criminalize activities that support cyber-criminal operations [22, 18]. While neither statute explicitly prohibits ransom payments, paying ransomware demands may be prosecuted under provisions related to abetment of cybercrime or money laundering, especially if the payment funds a criminal enterprise.

Shwapno's decision not to pay the ransom aligns with legal caution, as facilitating payments to cyber-criminals could expose the company to prosecution under these laws.

Long-Term Legal Risks if the Company Pays

1. **No Guarantee of Non-Disclosure.** Paying the ransom does not guarantee that the stolen data will not be published or re-sold, exposing the company to ongoing liability.
2. **Regulatory and Sanctions Exposure.** If the attackers or their affiliates are later sanctioned, any previous ransom payment could retrospectively violate regulations, leading

to fines and reputational damage [25].

3. **Recidivism and Repeated Attacks.** Research shows that paying ransoms increases the risk of being targeted again, either by the same attackers or others who learn the victim is likely to pay [23].
4. **Regulatory Scrutiny.** Shwapno, as part of ACI PLC, could face scrutiny from the Bangladesh Securities and Exchange Commission (BSEC) for failure to disclose such a payment, with potential personal liability for board members.
5. **Legal Precedent in Customer Lawsuits.** Paying the ransom could be seen as an admission that the data was stolen, strengthening potential class-action lawsuits from the affected customers.

Shwapno's refusal to pay the ransom is legally prudent, aligning with global enforcement guidance and mitigating long-term legal risks [34].

Question 5

Most data protection laws impose a duty on data controllers to implement *adequate* security measures. If forensic analysis reveals that Shwapno's customer database was stored in plaintext, this would likely constitute a failure to meet the required security standards, regardless of the hacker's actions.

The principle here is that the hacker's criminal act does not automatically relieve Shwapno of liability for its own negligence. In tort law, this is similar to the "novus actus interveniens" principle, where only unforeseeable events break the chain of causation. Cyberattacks are foreseeable, especially for retailers with millions of customer records [21].

Bangladeshi Legal Framework

ICT Act 2006 (Amendment 2013). While the ICT Act criminalizes unauthorized access, it does not impose explicit data protection duties on companies [18]. Bangladesh lacks a standalone data protection law, leaving a regulatory gap.

Digital Security Act 2018. This Act focuses on cybercrime but may allow for negligence claims in civil court if data is stored without encryption [22].

Consumer Rights Protection Act 2009. Inadequate protection of consumer data could be considered a deficiency in service, potentially leading to enforcement action.

Comparative Standards

Under the **EU GDPR** (Art. 32), failure to encrypt personal data where feasible is a breach of the security obligation, regardless of a breach occurring [21].

Industry standards like **PCI DSS** require encryption of payment data at rest. If Shwapno stored such data unencrypted, it would violate these standards [17].

Conclusion on Liability

If the database was unencrypted, Shwapno faces significant legal risks:

- Tortious negligence for failing to encrypt sensitive data.

- Potential regulatory action under consumer protection laws.
- Civil suits from customers affected by the breach.
- Reputational damage, particularly for ACI PLC's disclosure obligations.

The hacker's actions do not absolve Shwapno of its responsibility to protect customer data [21, 17]. As reported, Shwapno's database was accessible without sufficient controls, reinforcing the negligence argument [32].

2 The "SpiderKash" Leak

Question 1

DKIM, as outlined in Crocker, Hansen, and Kucherawy [16], allows email servers to sign outgoing messages with a private RSA key, with the public key published in DNS. Forensic investigators can authenticate leaked emails using these steps:

1. **Extract the header.** Open the raw .eml file, find the DKIM-Signature: field, and note the signing domain (d=), selector (s=), signed fields (h=), and the Base64 signature (b=).
2. **Retrieve the public key.** Query DNS for the public key at [selector]._domainkey.google.com [16].
3. **Verify the signature.** Using tools like opendkim-verify or Python's dkim library, recompute the canonical hash of the signed headers and body, then compare it with the decrypted b=.

If the signature matches, it confirms the email passed through Google's infrastructure unaltered, proving it couldn't have been fabricated without access to Google's private key. TechCrunch verified the authenticity of a subset of Patel's leaked emails using this method [36]. According to Kent et al. [14], the email headers must be preserved during the forensic process. However, DKIM authenticates the *sending domain*, not the individual sender, and fields omitted from h= are not protected.

Question 2

Since Gmail is hosted on Google's servers, physical seizure of the server is not possible. The forensic steps for Cloud Acquisition (e.g., Gmail) differ significantly from those of traditional Physical Acquisition (e.g., laptop hard drives), as follows [14]:

- **Legal basis:** Physical acquisition requires a search warrant and device seizure. In contrast, cloud acquisition requires a court order under 18 U.S.C. §2703(b) served on Google [10].
- **Collection:** For physical acquisition, a write-blocked bitwise image is created using tools like FTK Imager or dd. For cloud acquisition, tools like Google Takeout (MBOX) or the Gmail API (users.messages.get) are used.
- **Scope:** Physical acquisition captures the entire drive, including slack space and deleted files. Cloud acquisition is limited to logical data, with deleted items being purged after 30 days.

- **Integrity:** For physical acquisition, a SHA-256 hash of the image is generated. For cloud acquisition, each exported file is hashed, and a production hash from Google can be requested.
- **Tooling:** Physical acquisition is typically performed using tools like Autopsy, EnCase, or X-Ways. For cloud acquisition, Magnet AXIOM Cyber and Cellebrite UFED Cloud Analyzer are commonly used.

Two crucial cloud-specific steps include: (1) issuing a preservation letter under FRCP Rule 37(e) [20] to prevent data from being purged, and (2) requesting Google Account Activity logs via the Admin SDK to obtain attacker IP addresses and session timestamps. The main distinction lies in the fact that physical acquisition is a complete, self-contained process, whereas cloud acquisition is dependent on the provider, limited by retention policies, and provides only a logical copy of the data.

Question 3

EXIF metadata (JEITA EXIF 2.32) embedded in JPEG and HEIC files provides both a timestamp and a location. Running **ExifTool** (`exiftool -all= -csv`) across the dump, the investigator focuses on three tags:

- `DateTimeOriginal` — shutter timestamp, cross-referenced against publicly verifiable records to confirm a claimed 2015 date is plausible.
- `GPSLatitude/GPSLongitude` — plotted in Google Earth to verify the location matches the claimed event venue.
- `ModifyDate (XMP)` — a discrepancy with `DateTimeOriginal` indicates post-capture editing or file re-saving.

To distinguish cloud from physical backup origin: Google Photos strips certain EXIF fields and adds XMP upload-timestamp data, whereas photos recovered from a local backup drive retain full, unmodified EXIF as written by the capture device. In the SpiderKash case, folder metadata showed files last modified on May 21, 2025 [37], consistent with expert assessments that Handala had held the data since a prior intrusion rather than maintaining live access.

Question 4

Authorisation to investigate “evidence of a hack” does not confer unrestricted access to every file in the account. The Fourth Amendment’s *particularity doctrine* requires a warrant to specifically describe the items to be seized [3]. In *Riley v. California* [19] the Supreme Court held that a personal digital account contains “the privacies of life” and cannot be treated as a single physical object. Applied here, the warrant scopes the search to artefacts *of* the hack, such as OAuth authorisation logs, forwarding rules, anomalous login records, and session tokens, not to personal photographs or attorney-client privileged emails found incidentally.

The *plain view* doctrine (*Coolidge v. New Hampshire* [5]) permits action on incriminating evidence encountered during a lawful search, but in digital environments the Ninth Circuit in *United States v. Comprehensive Drug Testing, Inc.* [15] required investigators to use *search protocols*, such as keyword filters, date-range, and file-type restrictions, to prevent systematic over-breadth. The Stored Communications Act [10] separately limits compelled disclosure to

content material related to the stated offence, excluding personal communications outside the scope of the hack investigation.

In practice, investigators must deploy a **taint team** to pre-screen data for relevance and privilege, quarantine out-of-scope material without examining it, and obtain a supplemental warrant before reviewing any additional data category. The Budapest Convention [12] reinforces these boundaries internationally, mandating that all digital investigative measures be proportionate to the offence.

Question 5

The *Fruit of the Poisonous Tree* doctrine, established in *Silverthorne Lumber Co. v. United States* [1] and refined in *Wong Sun v. United States* [4], renders inadmissible evidence derived from an unconstitutional government search. The critical qualifier is *government*: the Fourth Amendment's exclusionary rule applies only to state actors.

In *Burdeau v. McDowell* [2], the Supreme Court held that evidence stolen by a private party and handed to the government was admissible because no government actor had committed a constitutional violation. *United States v. Jacobsen* [8] reaffirmed this: government re-inspection of a package already opened by FedEx employees did not constitute a Fourth Amendment search. Applied to SpiderKash, Handala is a private foreign entity, a prosecutor's use of the leaked material would likely *not* trigger the exclusionary rule, provided the government played no role in the breach.

The analysis changes if the government directed or acquiesced in Handala's conduct. Under *United States v. Walther* [6], the two-part test asks: (1) did the government know of and acquiesce in the intrusion, and (2) did the private party intend to assist law enforcement? If both are satisfied, the breach is re-characterised as governmental and the evidence becomes suppressible. Even where the material is admissible, a warrant derived from the tainted leak requires independent grounding: the *independent source* doctrine [11] and *inevitable discovery* rule [7] provide admissibility only where subsequent evidence-gathering was genuinely unconnected to the hack. Finally, relying on Handala's data implicates the Computer Fraud and Abuse Act [9] (18 U.S.C. § 1030): even if technically admissible, doing so creates the appearance of benefiting from criminal intrusion, generating ethical and appellate risk.

3 Digital Forensics Tool

Sleuth Kit(TSK)

What is Sleuth Kit?

Sleuth Kit (TSK) is an open-source collection of forensic tools used to analyze disk images and file systems [24]. It is designed to help investigators examine file structures, recover deleted data, and extract important forensic evidence from various types of file systems (such as NTFS, FAT, EXT, and HFS+). It provides a detailed view of the file system's structure, including metadata and timestamps, and is effective in uncovering hidden or fragmented data.

Phase in the Forensic Process:

Sleuth Kit is primarily used during the Examination and Analysis phases of the digital forensic process. It is instrumental in analyzing disk images and extracting data from file systems, including the recovery of deleted files and metadata analysis.

How it Ensures Integrity for Legal Admissibility:

- **Non-Invasive Analysis:** Sleuth Kit reads raw disk images without modifying the original data, ensuring that the evidence is not altered during the analysis.
- **Hashing for Integrity:** During acquisition and analysis, Sleuth Kit generates cryptographic hash values (MD5, SHA-1) of the data. These hashes allow investigators to verify the integrity of the evidence, ensuring that no tampering has occurred.
- **Detailed Reporting:** The tool produces comprehensive reports documenting all actions taken during the investigation, including file recovery, metadata, and timestamps, which helps maintain an accurate chain of custody.
- **Open-Source Transparency:** Being open-source, Sleuth Kit's methods and processes are publicly available for review, providing transparency and ensuring the reliability of the tool.

References

- [1] *Silverthorne Lumber Co. v. United States*. 251 U.S. 385. United States Supreme Court. Established the "Fruit of the Poisonous Tree" doctrine. 1920.
- [2] *Burdeau v. McDowell*. 256 U.S. 465. United States Supreme Court. Established the private search doctrine: Fourth Amendment exclusionary rule does not apply to purely private actors. 1921.
- [3] *Marron v. United States*. 275 U.S. 192. United States Supreme Court. 1927.
- [4] *Wong Sun v. United States*. 371 U.S. 471. United States Supreme Court. Refined the exclusionary rule and derivative evidence doctrine. 1963.
- [5] *Coolidge v. New Hampshire*. 403 U.S. 443. United States Supreme Court. Articulated the plain view doctrine for evidence discovered during a lawful search. 1971.
- [6] *United States v. Walther*. 652 F.2d 788 (9th Cir.) United States Court of Appeals, Ninth Circuit. Established two-part test for government participation in private searches: government knowledge/acquiescence, and private party intent to assist law enforcement. 1981.
- [7] *Nix v. Williams*. 467 U.S. 431. United States Supreme Court. Established the inevitable discovery doctrine: unlawfully obtained evidence is admissible if it would inevitably have been discovered through lawful means. 1984.
- [8] *United States v. Jacobsen*. 466 U.S. 109. United States Supreme Court. Held that government re-examination of a package previously opened by a private party did not constitute a Fourth Amendment search. 1984.
- [9] *Computer Fraud and Abuse Act*. As amended. Criminalises unauthorised access to protected computers; relevant to the legality of Handala's breach. 1986.

- [10] *Electronic Communications Privacy Act of 1986 (Stored Communications Act)*. Pub. L. 99-508. Governs government access to stored electronic communications; § 2703 requires a warrant or court order to compel disclosure from service providers. 1986.
- [11] *Murray v. United States*. 487 U.S. 533. United States Supreme Court. Affirmed the independent source doctrine: evidence obtained via a genuinely independent lawful search is admissible. 1988.
- [12] Council of Europe. *Convention on Cybercrime (Budapest Convention)*. Treaty ETS No. 185. Requires proportionality in digital investigative measures; widely adopted as a model for cybercrime law internationally. Budapest: Council of Europe, Nov. 2001. URL: <https://www.coe.int/en/web/conventions/full-list?module=treaty-detail&treaty-num=185>.
- [13] Brian Carrier. *File System Forensic Analysis*. Addison-Wesley Professional, 2005. ISBN: 0321268172.
- [14] Karen Kent et al. *Guide to Integrating Forensic Techniques into Incident Response*. NIST Special Publication 800-86. Gaithersburg, MD: National Institute of Standards and Technology, Aug. 2006. DOI: [10.6028/NIST.SP.800-86](https://doi.org/10.6028/NIST.SP.800-86). URL: <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-86.pdf>.
- [15] *United States v. Comprehensive Drug Testing, Inc.* 621 F.3d 1162 (9th Cir.) United States Court of Appeals, Ninth Circuit. Required forensic investigators to use search protocols (keyword filters, file-type restrictions) to prevent over-broad digital evidence examination. 2010.
- [16] D. Crocker, T. Hansen, and M. Kucherawy. *DomainKeys Identified Mail (DKIM) Signatures*. RFC 6376. Standards Track. Updates RFC 4871 and RFC 5672. Internet Engineering Task Force, Sept. 2011. URL: <https://www.rfc-editor.org/rfc/rfc6376>.
- [17] Paul Cichonski et al. *Computer Security Incident Handling Guide*. Tech. rep. SP 800-61r2. National Institute of Standards and Technology, 2012. URL: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>.
- [18] Government of Bangladesh. *Information and Communication Technology Act, 2006 (as amended 2013)*. Tech. rep. Ministry of Law, Justice and Parliamentary Affairs, 2013. URL: https://bida.gov.bd/site/view/policies_acts_legislation_and_relevant_documents.
- [19] *Riley v. California*. 573 U.S. 373. United States Supreme Court. Held that a warrant is required to search a cell phone incident to arrest; recognised digital devices contain “the privacies of life”. 2014.
- [20] *Federal Rules of Civil Procedure*. Rule 37(e) governs obligations regarding electronically stored information (ESI) preservation and the consequences of failure to preserve. 2015.
- [21] European Parliament and Council of the European Union. *Regulation (EU) 2016/679 — General Data Protection Regulation, Article 32: Security of Processing*. 2016. URL: <https://gdpr-info.eu/art-32-gdpr/>.
- [22] Government of Bangladesh. *Digital Security Act, 2018*. Tech. rep. Ministry of Law, Justice and Parliamentary Affairs, 2018. URL: <https://bcc.gov.bd/site/page/Digital-Security-Act-2018>.
- [23] Cybersecurity and Infrastructure Security Agency. *Ransomware Guide*. Tech. rep. CISA, 2020. URL: <https://www.cisa.gov/stopransomware/ransomware-guide>.

- [24] Brian Carrier. *The Sleuth Kit*. <https://sleuthkit.org/>. 2021.
- [25] U.S. Department of the Treasury, Office of Foreign Assets Control. *Advisory on Potential Sanctions Risks for Facilitating Ransomware Payments*. Tech. rep. U.S. Department of the Treasury, 2021. URL: <https://ofac.treasury.gov/media/912981/download?inline>.
- [26] Mandiant. *Ransomware Protection and Containment Strategies: Practical Guidance for Endpoint Protection*. 2022. URL: <https://www.mandiant.com/resources/ransomware-protection-and-containment-strategies-practical-guidance-endpoint-protection>.
- [27] William Stallings. *Cryptography and Network Security: Principles and Practice*. 8th ed. Pearson, 2022.
- [28] CrowdStrike. *Initial Access: Understanding Threat Actor Techniques*. 2023. URL: <https://www.crowdstrike.com/cybersecurity-101/initial-access/>.
- [29] MITRE Corporation. *MITRE ATT&CK: Exfiltration (Tactic TA0010)*. Tech. rep. MITRE, 2023. URL: <https://attack.mitre.org/tactics/TA0010/>.
- [30] U.S. Department of Justice. *How to Protect Your Networks from Ransomware*. Tech. rep. U.S. Department of Justice, 2023. URL: <https://www.justice.gov/criminal-ccips/file/872771/download>.
- [31] Beyond Machines. *Shwapno retail chain suffers data breach affecting 4 million customers*. Mar. 2025. URL: https://beyondmachines.net/event_details/shwapno-retail-chain-suffers-data-breach-affecting-4-million-customers-p-2-0-p-t/gD2P6Ple2L.
- [32] The Business Standard. *Retail chain Shwapno hit by customer data breach, hackers seek \$1.5m*. Mar. 2025. URL: <https://www.tbsnews.net/bangladesh/retail-chain-shwapno-hit-customer-data-breach-hackers-seek-15m-1396081>.
- [33] The Business Standard. *Shwapno files GD seven months after customer data breach*. Mar. 2025. URL: <https://www.tbsnews.net/bangladesh/shwapno-files-gd-seven-months-after-customer-data-breach-1396991>.
- [34] The Daily Star. *Shwapno's database hacked, details of 40 lakh customers at risk*. Mar. 2025. URL: <https://www.thedailystar.net/business/news/shwapnos-database-hacked-40-lakh-customers-details-risk-4137566>.
- [35] The Financial Express. *Shwapno website hacked, customer data leaked online*. Mar. 2025. URL: <https://thefinancialexpress.com.bd/trade/shwapno-website-hacked-customer-data-leaked-online>.
- [36] Lorenzo Franceschi-Bicchierai and Zack Whittaker. *Iranian Hackers Claim Breach of FBI Director Kash Patel's Personal Email Account*. Journalists verified DKIM cryptographic signatures in leaked message headers, confirming authenticity of a subset of the SpiderKash emails. TechCrunch, Mar. 2026. URL: <https://techcrunch.com/2026/03/27/iranian-hackers-claim-breach-of-fbi-director-kash-patels-personal-email-account/>.

- [37] NBC News. *Iranian Hackers Publish Emails Allegedly Stolen from Kash Patel*. Reports metadata indicating folders were last modified May 21, 2025; cites expert analysis suggesting data was held by Handala prior to strategic release. NBC News, Mar. 2026. URL: <https://www.nbcnews.com/tech/security/iranian-hackers-publish-emails-allegedly-stolen-kash-patel-rcna265490>.
- [38] United States Department of Justice. *FBI Confirms Breach of Director Patel's Personal Email; Offers Reward for Handala Information*. Official confirmation of the breach; statement that exposed material is "historical in nature and involves no government information". U.S. Department of Justice, Mar. 2026. URL: <https://komonews.com/news/nation-world/kash-patel-email-hacked-by-iranian-linked-hacking-group-doj-confirms-fbi-director-photos-personal-inbox-handala-hack-team>.